BTS SIO – OPTION SISR – BLOC 3 – 1re ANNÉE

Correction des exercices

Protéger les données à caractère personnel – Thème 1 – Séances 1 et 2

Exercices rapides, quiz de fin de séance et étude de cas FitZone (parties A, B et C)

TWAGIRUMUKIZA

Version du 21 octobre 2026

Séance 1 – Corrigés

Mini-exercice de qualification

(a) l'adresse IP d'un visiteur ; (b) un arrêt maladie dans un dossier RH ; (c) la moyenne de ventes par magasin ; (d) l'empreinte digitale utilisée pour badger ; (e) l'identifiant haché d'un client.

Corrigé

(a) DCP · (b) donnée sensible (santé) · (c) non DCP · (d) donnée sensible (biométrie) · (e) DCP (pseudonymisation).

Exercice de classement

Corrigé

(a) déstabilisation (défiguration) / intégrité · (b) espionnage (spear phishing) ou cybercriminalité / confidentialité · (c) cybercriminalité (ransomware) / disponibilité (+ confidentialité si exfiltration) · (d) espionnage (point d'eau) / confidentialité.

Quiz de fin de séance 1

N°	Question	Réponse	Explication
1	Une adresse IP est-elle une DCP ?	**Oui, par identification indirecte**	Elle peut identifier indirectement une personne.
2	Un hash SHA-256 d'e-mail est-il anonyme ?	**Non : pseudonymisation, donc toujours une DCP**	Hacher une liste de candidats suffit à retrouver l'original.
3	Quel principe est violé si l'on garde indéfiniment les CV refusés ?	**Limitation de la conservation**	Une durée de conservation doit être définie.
4	Un ransomware chiffre la base clients. Quel(s) critère(s) ?	**Disponibilité, et confidentialité si exfiltration**	Double extorsion : chiffrement et copie des données.
5	Laquelle est une donnée sensible (art. 9) ?	**Empreinte digitale**	Donnée biométrique.
6	Plafond de l'amende la plus élevée du RGPD ?	**20 M€ ou 4 % du CA mondial (le plus élevé)**	Ce sont des plafonds, pas des montants automatiques.
7	Un disque tombe en panne sans sauvegarde : sûreté ou sécurité ?	**Sûreté, et c'est une violation (perte de disponibilité)**	Le RGPD ne distingue pas : l'atteinte aux données suffit.
8	Les trois éléments de la preuve ?	**Authentification, imputabilité, traçabilité**	Preuve = non-répudiation.
9	Pourquoi un compte administrateur partagé est-il un problème ?	**Pas d'imputabilité : on ne sait pas qui a fait quoi**	Un compte = une personne.
10	Délai de notification d'une violation à la CNIL ?	**72 heures**	Week-ends et jours fériés compris.

Séance 2 – Corrigés

Quiz de fin de séance 2

N°	Question	Réponse	Explication
1	Événement futur possible, identifiable et quantifiable ?	**Risque**	Un aléa n’est pas quantifiable ; un imprévu n’est pas identifiable.
2	Ne pas mettre à jour après une alerte de faille, c’est…	**Une faute (et déjà un problème)**	Une faute est une erreur connue et non corrigée.
3	Formule de la criticité ?	**P × G**	Criticité = Probabilité × Gravité.
4	P = 4 et G = 3 : quelle criticité ?	**12**	4 × 3 = 12.
5	Seuil d’acceptabilité retenu en cours (matrice 5 × 5) ?	**≥ 10**	Au-delà, des actions préventives sont obligatoires.
6	Ordre logique de l’inventaire du SI ?	**Métiers et données → applications → équipements**	On va du métier vers la technique.
7	Principe de la défense en profondeur ?	**Plusieurs lignes de défense indépendantes**	La perte d’une ligne mène à un niveau plus fort.
8	Souscrire une cyberassurance revient à…	**Transférer**	Réduire, éviter, transférer ou accepter.
9	Le troisième facteur de l’AMDEC ?	**Indéterminabilité**	Probabilité de ne pas détecter l’incident à temps.
10	Un traitement biométrique à risque élevé exige…	**Une AIPD (art. 35)**	Analyse d’impact relative à la protection des données.

Étude de cas FitZone – corrigé complet

Réf.	Événement redouté	Critère	P	G	C	Niveau
R1	Fuite des certificats médicaux	Confidentialité	4	5	20	Prioritaire
R2	Ransomware sur serveur et sauvegarde USB	Disponibilité	4	4	16	Prioritaire
R3	Diffusion d’images des vestiaires	Confidentialité	3	4	12	À traiter
R4	Modification d’IBAN sans auteur identifiable	Intégrité + preuve	3	4	12	À traiter
R5	Fuite des empreintes digitales	Confidentialité	2	5	10	À traiter
R6	Panne disque sans sauvegarde valide	Disponibilité	3	3	9	À surveiller

Mesures clés : droits par groupe et attestation d’aptitude au lieu du certificat (minimisation) ; sauvegarde 3-2-1 avec copie hors ligne et test de restauration ; retrait des caméras des vestiaires et durée de conservation ; comptes nominatifs et journalisation ; alternative badge et AIPD pour la biométrie ; registre, référent RGPD, contrats sous-traitants, charte d’usage.

Corrigé A : cartographie

Traitement	Données	Sensibles ?	Support / accès	Problèmes relevés
Gestion des abonnements	Identité, coordonnées, IBAN, photo	Non (financières : vigilance)	Serveur local ; tous les salariés	Accès non limité ; compte admin partagé
Suivi d'aptitude médicale	Certificat médical	Oui – santé	Dossier partagé ouvert à tous	Base légale / consentement explicite à vérifier ; accès trop large ; minimisation (une attestation suffit)
Contrôle d'accès biométrique	Empreinte digitale	Oui – biométrie	Lecteur + base	Régime strict ; alternative badge ; AIPD probable
Newsletter	Nom, e-mail	Non	Outil en ligne (sous-traitant)	Conservation excessive ; contrat sous-traitant ; consentement
Vidéosurveillance	Images	Non en soi	Disque local	Vestiaires disproportionné ; durée non définie ; affichage
Communication des coaches	Noms, objectifs de santé	Oui – santé	WhatsApp, smartphones personnels	Hors contrôle de l'entreprise ; transfert possible hors UE

Inventaire – Actifs primordiaux : gestion des abonnements, suivi d'aptitude médicale, contrôle d'accès biométrique, vidéosurveillance, newsletter. Supports : logiciel de gestion, outil de newsletter, WhatsApp, système du lecteur d'empreinte. Équipements : serveur de l'arrière-boutique, disque USB, smartphones des coaches, caméras, lecteur d'empreinte, Wi-Fi d'accueil.

Corrigé B : vulnérabilités et menaces

R1 : menace cybercriminalité / erreur interne ; vulnérabilité : dossier ouvert à tous, pas de chiffrement. R2 : cybercriminalité ; sauvegarde connectée en permanence, mot de passe faible, Wi-Fi partagé (disponibilité + confidentialité). R3 : malveillance interne ; visionnage libre, durée illimitée. R4 : fraude interne ; compte administrateur partagé, aucune journalisation. R5 : espionnage / cybercriminalité ; données irremplaçables (non révocables). R6 : sûreté (accident) ; aucun test de restauration.

> Le défaut de mise à jour du logiciel de gestion (P = 5, G = 2, C = 10) est un risque perturbateur : on supprime la cause plutôt que de l'« accepter ».

Corrigé C : plan de prévention (extrait)

Risque	C	Mesure (couche)	Responsable	Prév.	Répar.	État
R1 Fuite certificats	20	Droits par groupe, chiffrement, ne conserver qu'une attestation (Donnée) – minimisation	Direction + prestataire SISR	✘ à faire	✘ procédure de notification 72 h	Rouge
R2 Ransomware	16	Sauvegarde 3-2-1 hors ligne ou immuable, test de restauration, MFA, Wi-Fi séparé (Réseau, Machine)	Prestataire SISR	✘ à faire	✘ plan de restauration	Rouge
R3 Vestiaires	12	Retirer les caméras, fixer une durée, afficher l'information (Politique)	Direction	✘ à faire	–	Orange
R4 Modification d'IBAN	12	Comptes nominatifs, mots de passe robustes, journalisation (Application, Preuve)	Direction	✘ à faire	✔ si logs exploitables	Orange

R5 Empreintes	10	Alternative badge, consentement explicite, AIPD, chiffrement des gabarits	DPO / référent RGPD	✘ à faire	✘	Orange

Gouvernance : supprimer les contacts inactifs et définir des durées de conservation (art. 5.1.e) ; cesser les échanges de données de santé sur WhatsApp personnel, utiliser un outil validé et une charte ; tenir un registre ; désigner un référent RGPD ; encadrer les sous-traitants par contrat ; sensibiliser le personnel.